

Asbatech CRM — Attendance Security Audit

Document: Employee & Admin attendance security review

Product: Asbatech CRM · Module: Time & Attendance

Generated: June 5, 2026

Summary

Core employee monitoring (tab close, cursor idle, breaks, clock in/out) is implemented and working. Laptop sleep requires the desktop agent. Two API routes lack authentication (critical). One logic bug may false-alarm when switching browser tabs while Attendance stays open in background.

1. Employee security features

#	Security	How it works	Status
1	Clock in / clock out	Employee must clock in to start shift; clock out ends shift.	Working
2	Official break	First break is official; must end before another.	Working
3	Extra break	Second break requires a written reason.	Working
4	Tab close	Closing the Attendance browser tab notifies admin and records away time.	Working
5	Other tabs / sites	Switching to Gmail, YouTube, etc. is allowed — not reported as tab close.	Mostly working*
6	No mouse / keyboard	~10 seconds no activity → away / break recorded (browser).	Working
7	Laptop sleep / lock	Win+L, lid close, sleep → away after ~10 sec via desktop agent.	Needs agent
8	Agent required for clock-in	UI blocks clock-in if agent not installed.	UI only**
9	Away notices	Employee sees warnings (cursor, sleep, tab reopened).	Working
10	Break minutes	Total counted away + breaks in Today's summary.	Working
11	Page scope	Browser monitoring runs only on /attendance page.	By design

* See bug #1 — cursor idle may still fire if Attendance tab is open but hidden in background.

** API does not enforce agent check — can be bypassed with direct API call.

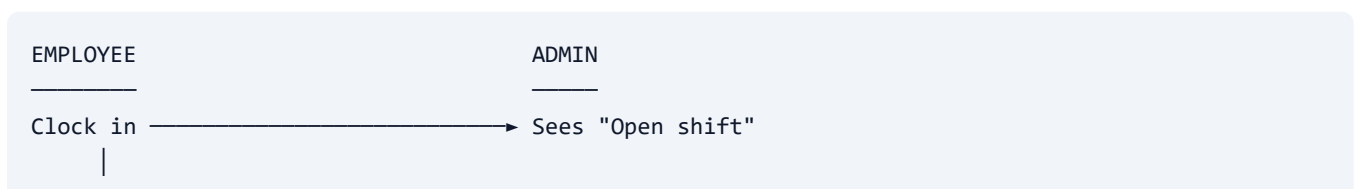
2. Admin security features

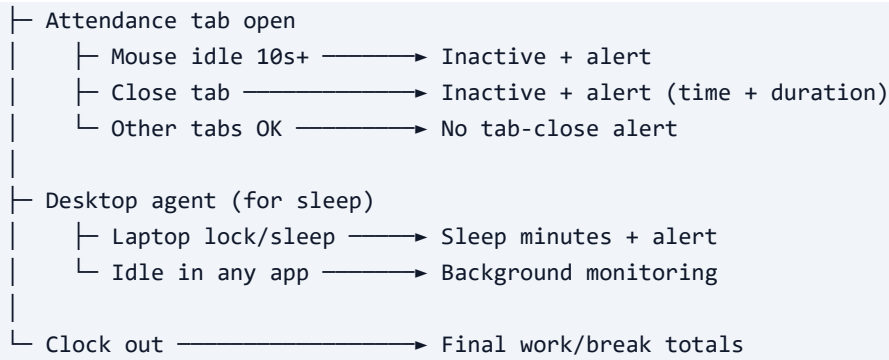
#	Feature	What admin gets	Status
1	Executive dashboard	Agent health table, employee rows, click for detail.	Working
2	Attendance detail popup	Clock in/out, work/break/inactive/sleep, break list.	Working
3	Tab close alerts	Notification when employee closes Attendance tab.	Working
4	Tab reopen alerts	Notification when employee returns + duration away.	Working
5	Cursor idle alerts	Notification after ~10 sec no mouse/keyboard.	Working
6	Sleep alerts	Notification when agent detects lock/sleep.	Agent only
7	Agent health	Running / Installed / No activity / Not installed.	Working
8	Live status	Active / Inactive / Break / Offline + reason.	Working
9	Daily / range reports	Data loads on server.	Partial UI
10	In-app notifications	Stored in DB for admins.	No bell UI
11	Manager role	APIs support managers.	Admin UI only

3. Policy thresholds (attendance-policy.ts)

Rule	Threshold
Tab close away	10 seconds (browser tab unload only)
Cursor idle away	10 seconds
Laptop sleep / lock away	10 seconds (desktop agent)
Activity heartbeat (browser)	60 seconds ping while active
Agent "running"	Signal within 180 seconds
Agent stale alert	10 minutes no signal during open shift

4. How monitoring flows





5. What is working well

- Tab close vs tab switch (main business rule)
- Cursor idle detection on Attendance page
- Break rules (official + extra with reason)
- Server-side away compliance and break minutes
- Admin employee detail with live totals
- Agent health date scoping (today, not yesterday)
- Desktop agent code for sleep/lock (when installed)
- API auth on most attendance routes

6. Errors and gaps

Critical Security holes

ID	Problem	Risk
A	/api/reports/attendance-summary has no login	Anyone can see all employees' work/break totals
B	/api/exports/attendance has no login	Anyone can download full attendance CSV

High Logic / trust issues

ID	Problem	Effect
1	Tab switch + cursor idle conflict	If Attendance tab stays open in background, cursor idle may fire after ~10s even though switching tabs is allowed.
2	Laptop sleep without agent	Sleep/lock not detected in browser only. Employees without verified agent show Sleep: 0.
3	Monitoring only on /attendance	Other CRM pages are not browser-monitored; agent needed for background.
4	Clock-in agent check is UI-only	API allows clock-in without agent verification.
5	"Manager notified" text	UI says manager; server notifies admins only.

Medium Incomplete features

- AdminAttendanceLivePanel built but not wired to dashboard
- Daily/range report tables not fully shown in UI
- No notification bell in header for attendance alerts
- Managers have APIs but no full attendance dashboard like admin
- Re-clock-in same day may not reset all tab/cursor counters

7. Employee example checklist

Check	Typical result (browser-only employee)
Tab close security	Working — breaks show "Attendance tab closed"
Cursor idle security	Working — breaks show "no mouse/keyboard"
Laptop sleep security	Not active without verified agent
Sleep minutes	0 until agent installed and running
Admin visibility	Yes — via browser last seen and detail popup

8. Recommended fix priority

1. **Add authentication** to attendance-summary and exports/attendance APIs
2. **Pause cursor idle** when Attendance tab is hidden (fix tab-switch false alarm)
3. **Enforce agent check** on clock-in API (not only UI)
4. **Fix copy** — "Admin notified" instead of "manager notified"

5. **Add sleep status badge** on employee Attendance page
6. **Wire notification UI** for admins

9. Key file locations

Area	Path
Employee page	apps/web/src/app/(app)/attendance/page.tsx
Activity API	apps/web/src/app/api/attendance/activity/route.ts
Away compliance	apps/web/src/lib/attendance-away-compliance.ts
Policy	apps/web/src/lib/attendance-policy.ts
Desktop agent	apps/desktop-agent/src/windows/Program.cs
Admin dashboard	apps/web/src/app/(app)/dashboard/page.tsx
Employee detail	apps/web/src/components/attendance/AttendanceReportEmployeeDetailPanel.tsx
Agent health	apps/web/src/lib/attendance-agent-health.ts

10. Bottom line

Side	Overall
Employee	Core rules work (tab close, cursor idle, breaks). Sleep needs agent. Tab-switch + idle has one bug.
Admin	Dashboard + detail work well. Two APIs are open without login (serious). Notifications exist but are hard to see in UI.